

认证机制漏洞报告 (Lab4: 暴力破解一个保持登录状态的 Cookie)

1. 漏洞名称

认证凭证可预测 (Predictable Session Credentials) — 持久化登录 Cookie 构造与暴力破解

2. 漏洞等级

高危 (High)

3. 漏洞描述

该网站的“保持登录状态 (Stay logged in)”功能使用了可预测的客户端持久化凭证。生成的 stay-logged-in Cookie 是基于明文编码算法生成的: Base64(用户名 + ':' + MD5(密码))。

由于服务器完全信任该客户端提交的 Cookie, 且 MD5 存在大量在线彩虹表可查, 攻击者可以通过逆向算法, 结合密码字典和 Burp Suite 的 Payload 处理规则, 自动生成各种候选 Cookie, 暴力破解目标用户 (carlos) 的有效凭证, 从而无需密码直接登录其账户。

4. 漏洞位置

漏洞端点: GET /my-account

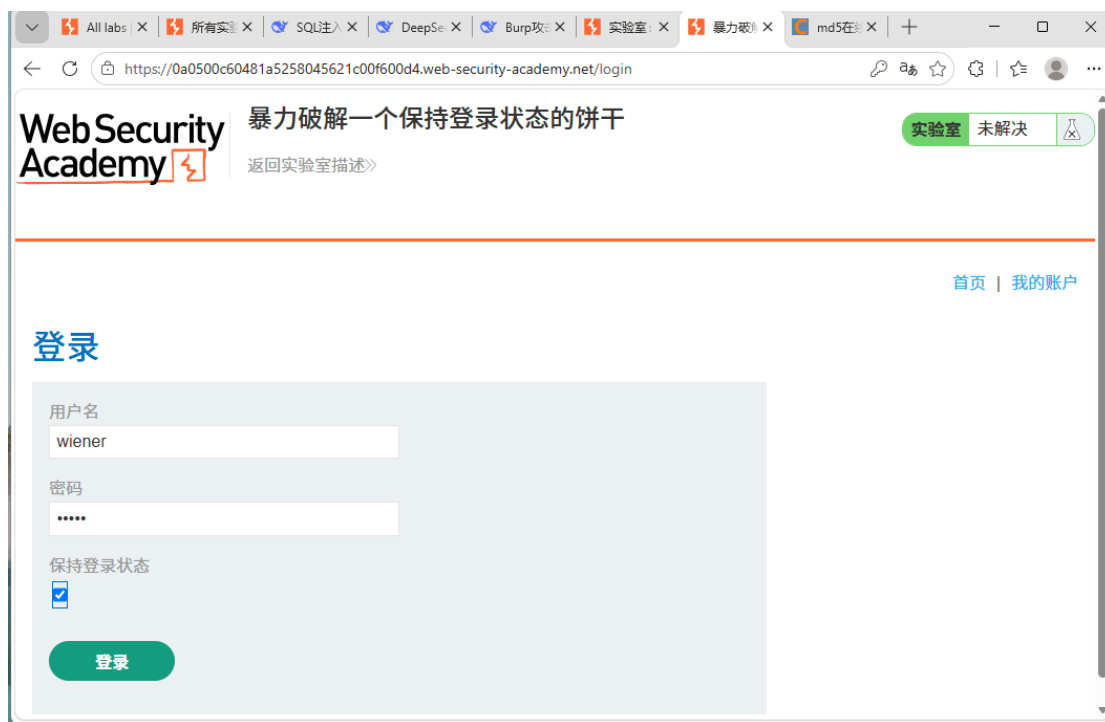
攻击向量: Cookie: stay-logged-in=...

5. 漏洞复现过程

第一步: 登录并发现持久化 Cookie

使用账号 wiener:peter 登录, 勾选“保持登录状态”复选框。登录后, 通过 Burp Suite 检查 Cookie。

图 1: 登录界面勾选保持登录状态

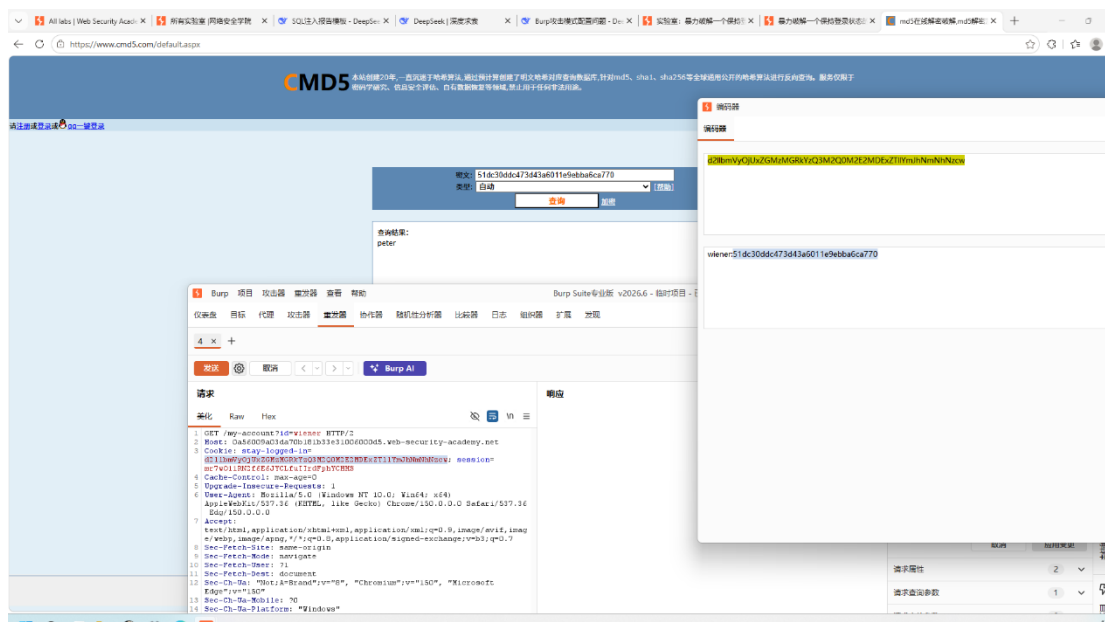


说明：触发后端生成持久化 Cookie。

第二步：逆向工程破解 Cookie 生成算法

在 Burp 的 HTTP History 中找到携带 stay-logged-in Cookie 的请求。使用 Burp 的 Inspector（或解码器）对其值进行 Base64 解码。

图 2：通过解码发现 MD5 哈希值

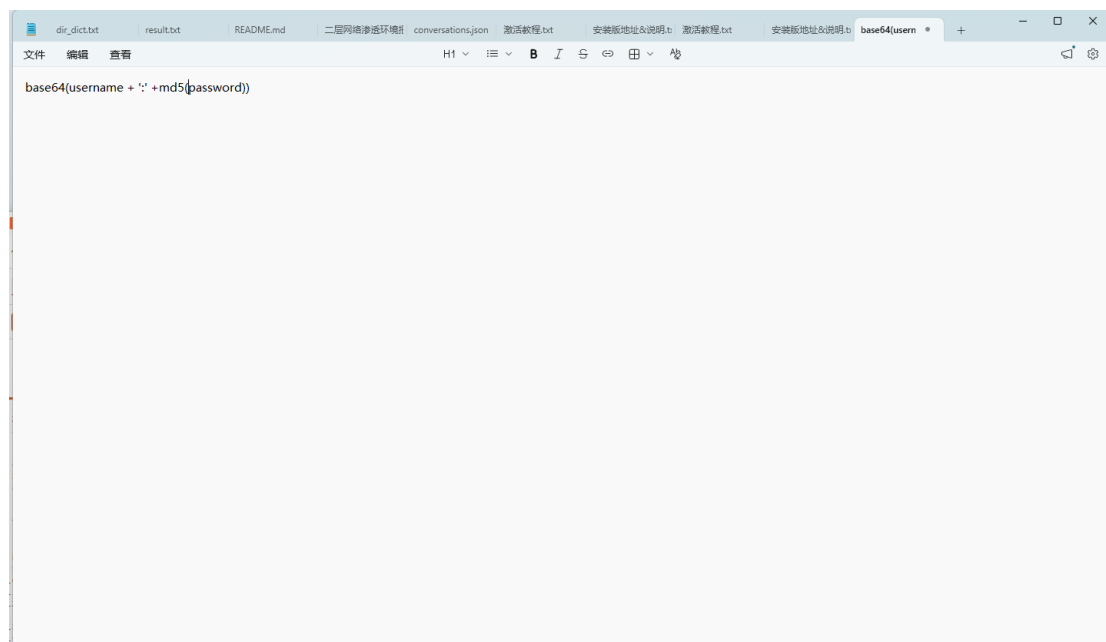


说明：stay-logged-in 解码后为 wiener:51dc30ddc473d43a6011e9ebba6ca770。通过在线 CMD5 网站反查，确认后半段 32 位字符串是密码 peter 的 MD5 哈希值。

第三步：确定算法公式并编写配置

根据解码结果，完全还原了后端生成该 Cookie 的逻辑公式：
`Base64(username + ':' + md5(password))`

图 3：记录算法逻辑



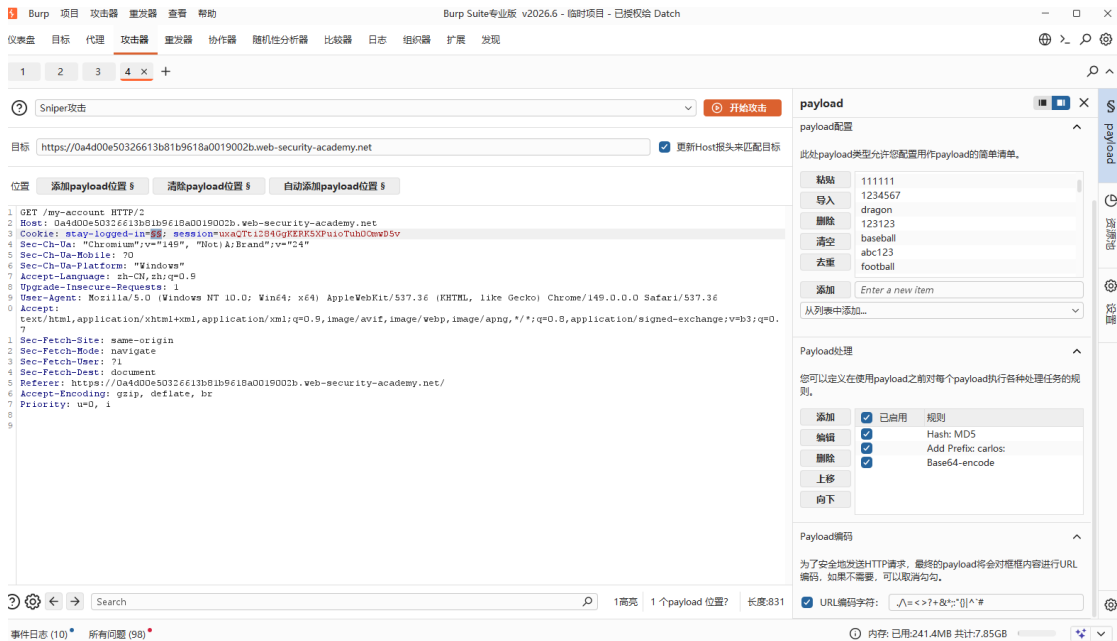
说明：明确攻击目标，即生成 carlos 的专属有效 Cookie。

第四步：配置 Burp Intruder 进行自动化 Cookie 生成

将校验请求发送至 Burp Intruder。利用 Burp 极其强大的 **Payload Processing（有效载荷处理）** 功能，配置一个自动化流水线：

1. 将候选密码列表设为 Payload。
2. 添加处理规则：**Hash: MD5** (将密码转为哈希)
3. 添加处理规则：**Add Prefix: carlos:** (拼接用户名)
4. 添加处理规则：**Base64-encode** (最终生成 Cookie)

图 4：配置 Burp Intruder 与 Payload Processing 规则



说明: Burp 的 Payload Processing 会将字典里的纯文本密码自动执行这三步, 瞬间变成携带身份信息的合法 Cookie。

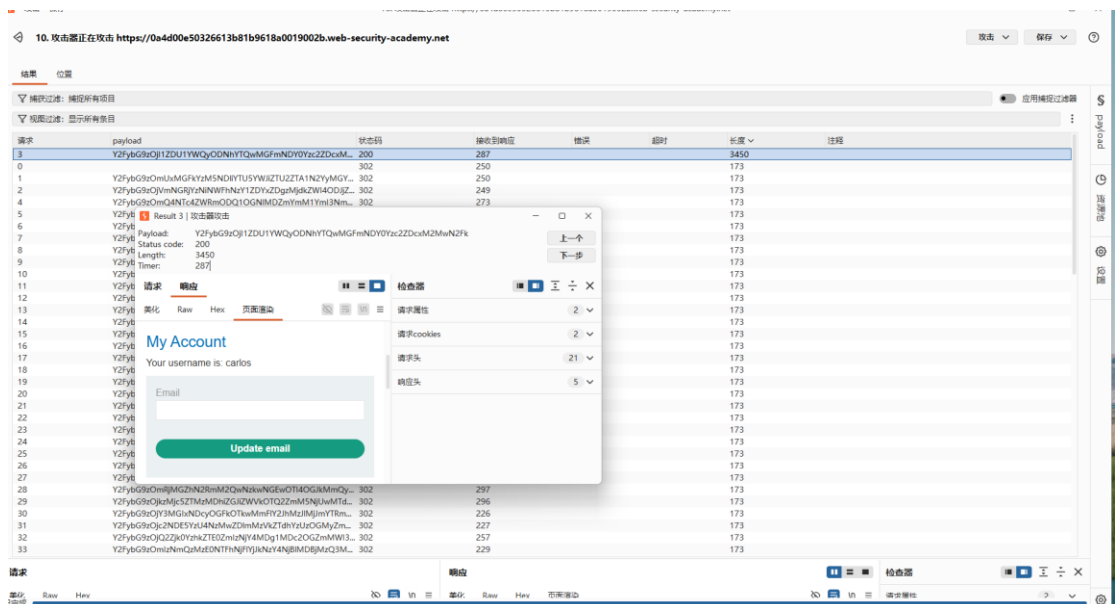
第五步: 设置过滤条件并启动攻击

为了在众多错误 Cookie 中快速找到正确的那个, 设置 Burp 的 **Grep - Match** 功能, 通过检测响应中是否包含 Update email 判断是否成功登录。

第六步: 分析攻击结果, 成功获取有效 Cookie

启动攻击后, 在结果列表中, 根据响应长度或 Update email 列的匹配情况, 定位到唯一返回 200 OK 的请求。

图 5: Burp 爆破结果, 发现有效响应

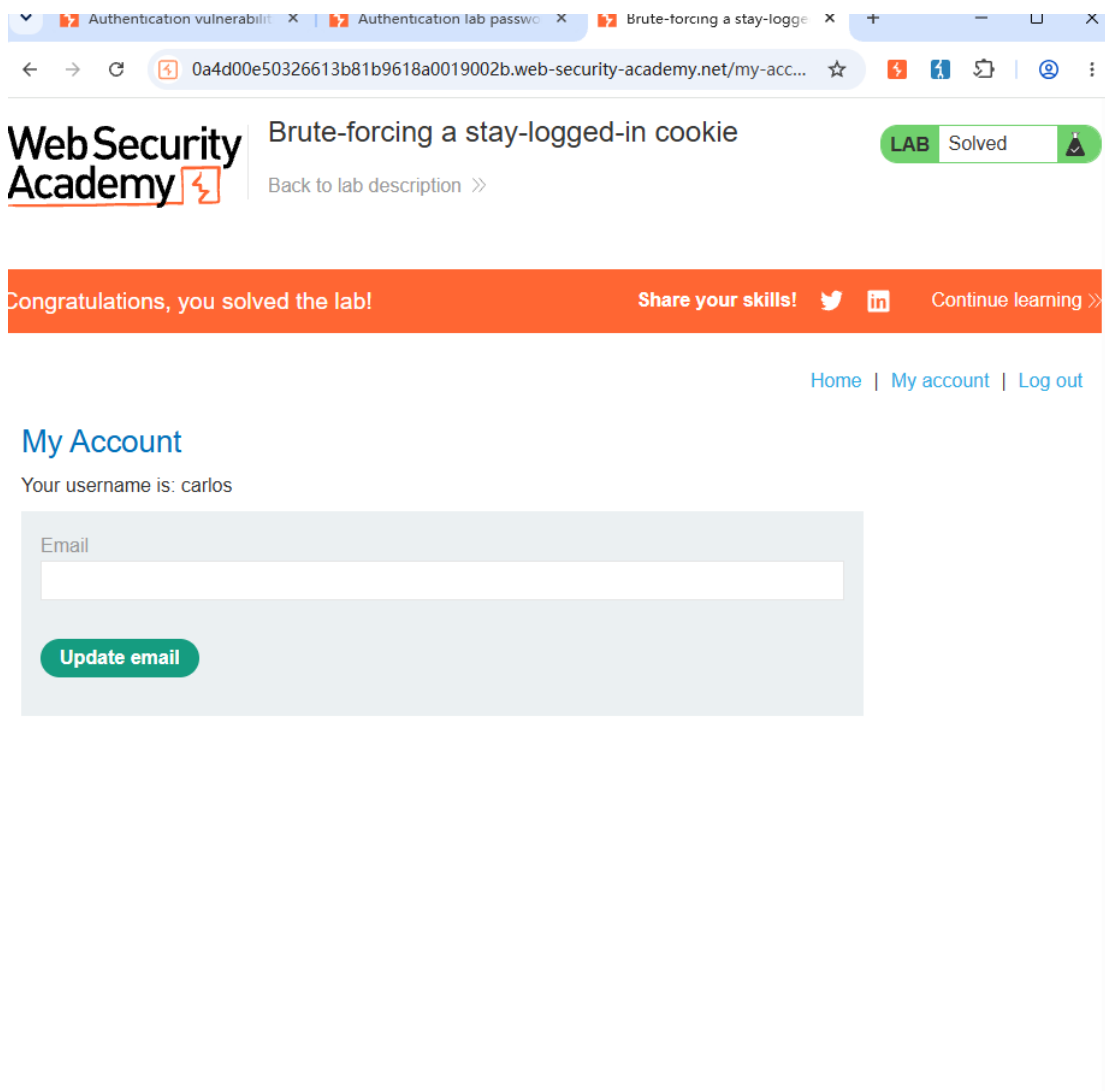


说明：该行对应的 Payload（最终生成的 Cookie）即为目标账户 carlos 的有效凭证。

第七步：利用有效 Cookie 登录并完成实验

在浏览器中编辑 Cookie，或直接访问 /my-account?id=carlos 并带上成功的 Cookie 值，成功进入目标账户页面。

图 6：成功登录 Carlos 账户并完成实验



说明：成功利用逆向算法与暴力破解，无需密码即可绕过登录，接管受害者账户。

6. 漏洞原理

该漏洞属于“不安全的客户端存储与加密算法滥用”：

1. **算法本身安全，但应用不当**：MD5 是哈希算法，虽然不可逆，但存在巨大的在线彩虹表。一旦 username 已知，只需将密码字典进行组合计算即可快速验证。
2. **服务器信任客户端凭证**：服务器将在浏览器端持久化的 Cookie 当作“身份令

牌”直接信任，没有结合服务端 Session 进行二次验证。

3. **攻击链**：攻击者通过逆向找到公式 -> 利用 Burp 自动化流水线 (Hash + 拼接 + Base64) -> 批量生成符合条件的有效 Cookie -> 送入服务器验证。

7. 漏洞影响

- **零交互凭证窃取**：攻击者即使不接触密码，只要能猜中密码字典，即可直接生成对应的 Cookie 登录目标账户。
- **大规模横向移动**：若黑客提前拖库了其他网站泄露的密码库，可利用自动化脚本快速验证该 Cookie 生成机制，批量接管所有用户。

8. 修复建议

- ① **使用强加密与签名 (HMAC)**：不要使用 Base64 这种纯可逆的编码来生成凭证。应使用服务端存储的密钥 (Secret Key) 对 username + ':' + 随机数 进行 HMAC-SHA256 签名，并将签名作为票据。
- ② **禁止客户端持久化重要凭证**：避免将用于“保持登录”的 Token 直接存在浏览器的 Cookie 里。应使用 JWT 并设置 HttpOnly 和 Secure 标志，或采用服务端 Redis 缓存 Session，仅给浏览器发一个随机 Session ID。
- ③ **登录状态回传验证**：当用户从客户端提交 stay-logged-in Cookie 时，服务器必须向数据库交叉验证该凭证是否依然有效且未被篡改。

9. 工具

- **Burp Suite** (Decoder 解码、Intruder 模块自动化爆破与 Payload Processing 处理)
- **CMD5 / MD5Online** (在线哈希反查工具)
- **PortSwigger Web Security Academy** (靶场平台)